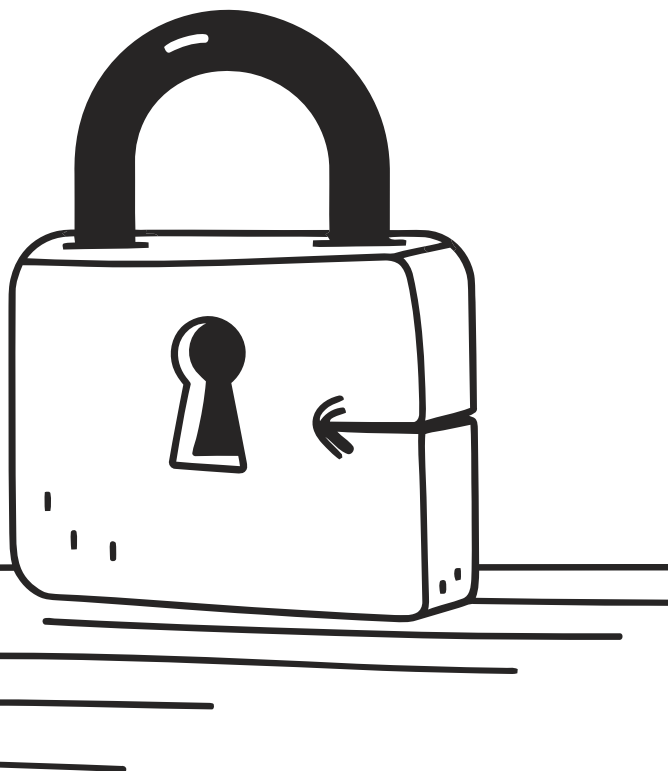




MT13 · Secrets, .env i claus

Configura integracions de forma segura. **El repositori no ha de contindre mai secrets reals.**

R5S2 · 45 MIN

Què és un secret?

🔑 Credencials

Contrasenyes i *application passwords*

🏛️ Tokens

Tokens d'API i d'accés

🔑 Claus privades

SSH, JWT, certificats

🔗 Cadenes sensibles

URLs de base de dades amb credencials

❌ Una clau exposada en un repositori públic és una incidència de seguretat immediata.



Bones pràctiques

Estructura de fitxers

```
# .gitignore
.env
*.env.local

# .env.example (sí al repo)
DB_HOST=localhost
DB_PORT=5432
DB_NAME=nom_base_dades
DB_USER=usuari
DB_PASS=

API_KEY=
SECRET_TOKEN=
```

Regles clau

- **.env** mai a Git — afegir al `.gitignore`
- **.env.example** sempre al repositori, sense valors reals
- Noms **descriptius i clars**: `STRIPE_SECRET_KEY`
- Error **comprensible** si falta una variable
- **Revoca** qualsevol clau que hages exposat

Errors habituals

❌ Commitejar `.env`

El fitxer amb valors reals va al repositori i s'exposa per sempre en l'història.

❌ Tokens al README

Documentar exemples amb claus reals o tokens de proves actius.

❌ Captures amb claus

Screenshots del terminal o d'eines que mostren el valor de la clau.

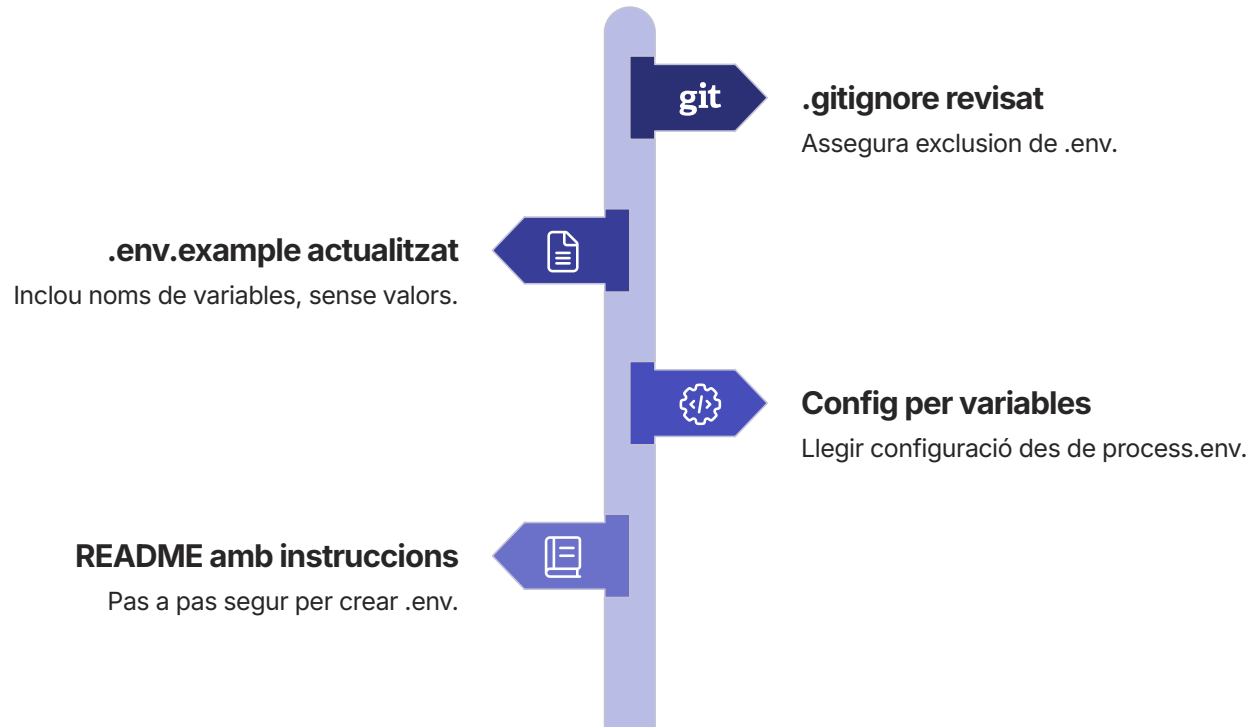
❌ Claus personals compartides

Usar la mateixa clau per a proves i per a producció o comptes personals.



Git recorda **tot l'història**. Eliminar un fitxer en un commit no esborra les dades anteriors.

Evidència del dia



Prova sense clau

- ✓ Un error clar i accionable és bona pràctica.



Reflexió final

Què passaria si publicasses ara el repositori?

✓ Objectiu assolit

`.env` fora de Git, `.env.example` al repositori, README documentat

↺ Si has exposat una clau

Revoca-la immediatament des del panell del servei. L'historial no s'esborra.